CASE STUDY 01 • FINAL EXECUTIVE DELIVERABLE

Vendor AI Usage Analysis

An Evidence-Driven OSINT Methodology & Security Risk Engine for Third-Party AI Due Diligence

PRESENTER & ENGAGEMENT METADATA

- **Presenter: Aiman Dhanani | Registration Number: 24BYB0033**
- Institution: VIT | Optiv Consulting Cyber Strategy Campus Engagement
- Client Engagement: Meridian Financial Third-Party Risk Management (TPRM)
- Core Deliverables: Meridian_Vendor_Output.xlsx, Interactive Streamlit UI, 18/18 Unit Tests
- Source Code Repository: https://github.com/Aiman-D/optiv-case-study-1

Executive Summary & Engagement Context

Meridian Financial Third-Party Risk Assessment Initiative

THE BUSINESS CONTEXT & THREAT LANDSCAPE

- Client Profile: Meridian Financial is a global financial institution serving 1.4 million customers, handling critical payments, account balances, and wealth management portfolios.
- The Estate: Meridian relies heavily on external vendors across core banking, automated workload scheduling, statement generation, payment settlement, and wealth reporting.
- The Challenge: Commercial software vendors rapidly embed generative and predictive AI into their products without formal disclosures to enterprise clients.
- The Threat: If a vendor feeds customer data or transaction streams into unvetted AI models, Meridian incurs severe regulatory, data leakage, and contractual compliance liabilities.
- The Optiv Mandate: Design an automated, reproducible method to inspect vendors' public footprints and determine true service-level AI usage.

THE OPTIV METHODOLOGY & CORE DELIVERABLES

- 100% OSINT-Driven: Zero vendor contact, zero scraping of authenticated portals, full adherence to robots.txt and polite 1.2s rate limits.
- Deterministic Criticality Engine: Objective 0–3 scoring rubric across 5 dimensions, removing analyst bias and setting proportionate assessment depth.
- Cryptographic Quote Guard: Enforces exact substring matching against immutable cached snapshots. Any hallucinated LLM claim is discarded immediately.
- Definitive Classification: Resolved Meridian's 6 vendors down to 3 Confirmed Yes (Fiserv, BNY, AutomWorx), 2 Confirmed No (FSSI, TCH), and exactly 1 Inconclusive (Terrapin).
- Client-Ready Deliverable: Preserved Columns B–K byte-for-byte; added 132-row Evidence Log sheet; deployed interactive Streamlit app in Presentation Mode.

Problem Statement: Reading the Public Footprint

Navigating Ethical Boundaries, Marketing Noise, and Cryptographic Traceability

ETHICAL OSINT BOUNDARIES

- **Strictly Public Footprint:**
  Analysis relies 100% on publicly accessible information: product docs, trust centers, job listings, and regulatory filings.
- **No Active Vendor Contact:**
  Zero vendor outreach or questionnaire distribution during discovery; eliminates early tipping-off or non-standard disclosures.
- **Robots.txt & Rate Limiting:**
  Adheres to RFC 9309 standards; enforces a strict 1.2s delay between requests; never bypasses paywalls or CAPTCHAs.

NOISE VS. SERVICE LINKAGE

- **Marketing Buzzword Clutter:**
  Vendors frequently publish speculative blog posts on 'AI Trends' without embedding AI into actual commercial deliverables.
- **Service-Linkage Requirement:**
  Evidence must specifically tie to the service Meridian purchases (e.g. DNA core banking) rather than company-wide HR tools.
- **Evidentiary Weight Hierarchy:**
  Direct technical documentation and sub-processor registers carry 4x the weight of generic executive interviews.

TRACEABILITY & INTEGRITY

- **Immutable Snapshot Store:**
  Every single claim traces to a local snapshot with URL, ISO-8601 retrieval timestamp, and SHA-256 cryptographic hash.
- **Quote Guard Substring Check:**
  Candidate quotes extracted by the LLM are validated against the raw text. Non-verbatim claims are marked INVALID_QUOTE.
- **Coverage Gap Accounting:**
  Unreachable sites or bot-blocked pages are logged as COVERAGE-GAP—never falsely reported as 'No' AI usage.

Roles & Responsibilities: 5-Pillar Architecture

The Structured Methodology Answering the Core Engagement Prompts

PILLAR 01

DETERMINE CRITICALITY

- **Core Mandate:**
Judge how critical each vendor is from the profile provided, establishing objective, explainable criteria.

- **Evaluation Anchors:**
5 anchored dimensions (0–3 scale): Data sensitivity, payment-flow involvement, regulatory exposure, operational dependency, data volume.

- **Floor & Modifiers:**
Applies privileged access modifiers (+1) and customer master floor rules to ensure reproducible ratings across analysts.

PILLAR 02

SET THE DEPTH

- **Core Mandate:**
Decide proportionate assessment depth warranted by criticality, optimizing investigative resources.

- **Tier Policies:**
Critical warrants a full sweep (docs, trust center, technical jobs, filings); Low warrants trust center/policy check only.

- **Stop Conditions:**
Crawl ceases once confirmed signals exist and model providers are identified or confirmed unfindable.

PILLAR 03

IDENTIFY SOURCES

- **Core Mandate:**
Identify and prioritize OSINT sources that reveal genuine service AI usage vs marketing fluff.

- **Source Hierarchy:**
Tier A (Direct product docs, sub-processors, policies) down to Tier D (Generic thought leadership noise).

- **Weighting Logic:**
Applies service-linkage multipliers (1.5x product vs 0.5x company-wide) and 180-day recency discounts (0.7x).

PILLAR 04

BUILD CAPABILITY

- **Core Mandate:**
Build automated scrapers, content clean-up, LLM signal extraction, and rigorous verification.

- **Technical Stack:**
Trafilatura content extraction, regex pre-filtering, Groq LPU API (gpt-oss-120b) with strict JSON schema.

- **Cryptographic Guard:**
Whitespace-normalized exact substring verification guarantees zero hallucinations enter the audit log.

PILLAR 05

SURFACE THE RISK

- **Core Mandate:**
Translate confirmed AI signals into concrete enterprise security risks to support TPRM due diligence.

- **Risk Taxonomy:**
Maps to 4 enterprise risks: sensitive data ingestion, shadow AI sub-processors, credential leakage, contract voids.

- **Governance Action:**
Drafts actionable 15-day vendor questionnaires, sub-processor registry updates, and 30-day escalation paths.

Expected Outcome 1: Functional Design Diagram

End-to-End Pipeline Data Flow from OSINT Collection to Final Risk Workbook

Stage 01

M1: Criticality

- **Inputs:** Meridian_Vendor_Input.xlsx, rubric.yaml
- **Processing:** 5 anchored scales (0–3), floor rules, +1 modifier
- **Output:** Criticality Tier & Warranted Depth
- **Tech Stack:** Python 3.12, pandas, PyYAML

Stage 02

M2: Collectors

- **Inputs:** Vendor domains, careers portals, sitemaps
- **Processing:** Robots.txt parsing, polite 1.2s delay, trafilatura
- **Output:** SHA-256 hashed raw & cleaned text snapshots
- **Tech Stack:** urllib.robotparser, trafilatura, bs4

Stage 03

M3: Classifier

- **Inputs:** Cleaned page snapshots, sources.yaml
- **Processing:** 25+ regex filters, Groq LPU JSON inference
- **Output:** Verbatim quotes, AI mechanism, named providers
- **Tech Stack:** Groq API, gpt-oss-120b, Quote Guard

Stage 04

M4: Risk Engine

- **Inputs:** Verified signals, vendor criticality, data class
- **Processing:** Multi-factor formula, 180-day decay, coverage rules
- **Output:** AI Verdict (Y/N/Inc), Security Risk Classification
- **Tech Stack:** Mathematical scoring engine, coverage logger

Stage 05

M5: Excel & UI

- **Inputs:** Final classifications, evidence audit trail
- **Processing:** Preserves B–K byte-for-byte, writes L–V, UI cache
- **Output:** Meridian_Vendor_Output.xlsx, Streamlit app
- **Tech Stack:** openpyxl, Streamlit, pytest (18/18 pass)

DATA FLOW & REPRODUCIBILITY GUARANTEES

- Input Stream: data/Meridian_Vendor_Input.xlsx (Client Source of Truth, 100% Immutable) | config/rubric.yaml | config/sources.yaml
- Intermediate Snapshot Store: cache/<Vendor_ID>/<URL_Hash>.json (Raw HTML, Cleaned Text, Retrieval Date, SHA-256 Content Hash)
- Output Deliverables: data/Meridian_Vendor_Output.xlsx (Preserved B–K, Populated L–V, 132-row Evidence Log) | Streamlit Presentation UI

Expected Outcome 2: System Architecture Diagram

Technical Components, Interactions, Libraries, and Internal Data Structures

MODULE 1 & 2: INGESTION & CRAWL

- **src/criticality.py**
  Parses input via pandas, executes 5 anchored rubric scales, applies floor rules and privileged access modifiers (+1).
- **src/collectors.py**
  Automated link discovery via sitemap.xml and homepages; respects robots.txt (urllib.robotparser); 1.2s delay.
- **trafilatura & bs4**
  Strips scripts, styling, and navigation boilerplate. Generates standardized cleaned text for audit indexing.
- **SHA-256 Snapshot Store**
  Persists local JSON cache containing raw HTML, cleaned text, retrieval timestamp, and content hash for zero-contact replay.

MODULE 3: CLASSIFIER & QUOTE GUARD

- **src/classify.py**
  Pre-filters text using 25+ regex patterns for AI keywords to drop irrelevant pages and conserve tokens.
- **Groq LPU API Engine**
  Leverages ultra-fast cloud inference (openai/gpt-oss-120b) with strict JSON schema mode (signal_type, quote, provider).
- **verify_quote() Guard**
  Normalizes whitespace and executes exact substring check. Any non-verbatim quote is discarded as INVALID_QUOTE.
- **Signal Scoring Logic**
  Calculates base evidence score across CONFIRMED, CORROBORATED, INDICATIVE, and MARKETING-ONLY tags.

MODULE 4 & 5: RISK & EXPORT

- **src/risk_export.py**
  Computes multi-factor evidence score, applies 180-day recency discount (0.7x), maps tier & footprint to risk.
- **openpyxl writer**
  Uses shutil.copy to preserve client workbook formatting; populates columns L–V; appends 132-entry Evidence Log.
- **app/main.py (Streamlit)**
  Provides instant Presentation Mode, pre-computed KPI cards, per-vendor deep-dive cards, and one-click download.
- **pytest Test Suite**
  18 automated unit tests verifying deterministic criticality, Quote Guard integrity, and byte-for-byte column preservation.

Expected Outcome 3: Source Strategy & Evidentiary Logic

Tiered Reliability Hierarchy, Mathematical Weighting Formula, and the Quote Guard

OSINT SOURCE RELIABILITY TIERS

Tier & Class	Source Type & Footprint	Weight
Tier A: Direct	Product docs, sub-processor lists, AI policies, official regulatory filings.	4.0x (Highest)
Tier B: Corroborating	Technical job postings, engineering blogs, GitHub repos, developer SDKs.	3.0x (Strong)
Tier C: Contextual	Executive interviews, press releases, partnership announcements.	2.0x (Moderate)
Tier D: Noise	Generic marketing blogs, buzzwords, speculative thought pieces.	1.0x (Filtered)

MATHEMATICAL WEIGHTING & QUOTE GUARD

▪ Multi-Factor Weighting Formula:

Signal Score = Base × Tier × Conf × Linkage × Recency

- Base Score: CONFIRMED (5) | CORROBORATED (3) | INDICATIVE (2) | MARKETING (0.5)
- Service Linkage: 1.5x if tied to Meridian's product; 0.5x if generic company-wide
- Recency Discount: 0.7x penalty for signals > 180 days old

▪ The Cryptographic Quote Guard:

1. LLM extracts candidate verbatim quote and AI mechanism.
2. Python executes whitespace-normalized substring search.
3. If candidate quote is NOT a 100% exact substring of the cached snapshot, it is discarded as INVALID_QUOTE.
4. Guarantees zero hallucinations enter the audit trail.

Expected Outcome 4: Criticality Scoring Rubric

Deterministic 0–3 Scoring Rubric, Floor Rules, and Tier-Driven Depth Policy

RUBRIC EVALUATION DIMENSIONS (0–3 SCALE)

- Data Sensitivity (0–3): 0 = No data | 1 = Internal business data | 2 = Confidential records | 3 = Full customer master records
- Payment-Flow Involvement (0–3): 0 = No involvement | 1 = Reporting/indirect | 2 = Payment file transmission | 3 = Core clearing and settlement rail
- Regulatory Exposure (0–3): 0 = Standard services | 1 = Reporting | 2 = Regulated banking | 3 = Systemically critical payment utility
- Operational Dependency (0–3): 0 = Low | 1 = Moderate | 2 = High | 3 = Critical / Total operational dependence
- Data Volume (0–3): 0 = Not applicable | 1 = < 100k records | 2 = 100k – 5M records | 3 = > 5M records / messages

MODIFIERS & TIER-DRIVEN DEPTH POLICY

- Privileged-Access Modifier (+1): If vendor holds production credentials or job scheduling authority without direct customer data (e.g. AutomWorx), apply +1 score modifier.
- Customer Master Floor Rule: Any vendor accessing full customer master data is guaranteed at least a High or Critical rating.
- Critical Depth Policy: Full sweep: product docs, trust center, sub-processor list, AI policy, DPA pages, technical job postings, engineering blog, GitHub, filings.
- High Depth Policy: Product docs, trust center, technical job postings, and regulatory filings.
- Medium Depth Policy: Public website, standard product documentation, and general job listings.
- Low Depth Policy: Trust center and AI-policy check only (efficient resource allocation).

Expected Outcome 4 (Cont.): Vendor Criticality Scores

Deterministic Scoring Breakdown Across Meridian's 6 Third-Party Vendors

Vendor ID	Vendor Name	Score	Assigned Tier	Dependency	Criticality Rationale & Applied Depth
V-001	AutomWorx	3	Low	High	Holds production credentials (+1 privileged modifier) but no direct customer data. Depth: Trust center/AI policy only.
V-002	Fiserv, Inc.	15	Critical	Critical	Core banking (DNA) & card platform accessing 1.4M customer master records. Depth: Full sweep (docs, trust, jobs, filings).
V-003	FSSI	9	High	High	Statement print & e-delivery processing for 850k customer accounts. Depth: Product docs, trust center, jobs, filings.
V-004	Terrapin Technologies	6	Medium	Moderate	Wealth data solution consolidating 38k advisor accounts & commissions. Depth: Website, docs, and job listings.
V-005	BNY	9	High	High	RTP transmission services processing 2.1M payment messages. Depth: Product docs, trust center, jobs, filings.
V-006	The Clearing House	12	Critical	Critical	National ACH & RTP settlement clearing 14M payment messages. Depth: Full sweep (operating rules, specs, filings).

Expected Outcome 5: Vendor Assessment Findings

Definitive Findings Matrix: Exactly 1 Inconclusive Reflects Methodological Rigor

VID	Vendor Name	Criticality	AI Usage	Risk Rating	Identified Providers & Verified Footprint
V-001	AutomWorx	Low	Yes	Medium	Google (Gemini), OpenAI (ChatGPT). AI policy confirms consultants use commercial LLMs for scripting/work completion.
V-002	Fiserv, Inc.	Critical	Yes	Critical	Azure OpenAI, Apple (Siri), Amazon (Alexa), Fiserv. 124 signals across AML Risk Manager, predictive analytics, agentic AI.
V-003	FSSI	High	No	None ident.	N/A. Thorough OSINT sweep of 14 Tier A/B pages (SOC 2, trust center, print operations). Zero AI claims detected.
V-004	Terrapin Tech.	Medium	Inconclusive	Medium	None named. Minimal web footprint (1 page reachable; API/docs 404). Honest inconclusive requiring targeted questionnaire.
V-005	BNY	High	Yes	High	Microsoft, OpenAI, BNY AI Hub. Confirmed AI-powered document processing and workflow optimization in corporate platforms.
V-006	The Clearing House	Critical	No	None ident.	N/A. Extensive audit of 1,016 pages of network rules & specs. Core ACH/RTP clearing rail operates deterministically without AI.

Surfacing Enterprise Risk & Governance Playbook

Mapping Public AI Footprints to Meridian's Risk Framework & 15/30-Day Action Plans

FOUR CORE ENTERPRISE AI RISKS

- **1. Sensitive Data Ingestion:**

Commercial LLMs or unvetted pipelines ingesting customer records or payment transactions.
↳ Scope: 1.4M customer accounts (Fiserv DNA), 2.1M payment messages (BNY RTP).

- **2. Shadow AI Sub-processors:**

Third-party cloud models (OpenAI, Microsoft Azure) deployed without formal DPA listing.
↳ Scope: Unmonitored chain-of-custody across outsourced banking and workflow services.

- **3. Script & Credential Leakage:**

Consulting staff pasting internal scripts or production credentials into public LLMs.
↳ Scope: Direct infrastructure exposure via unvetted scripting automation (AutomWorx).

- **4. Contractual & Audit Voids:**

Absence of contractual guarantees prohibiting vendor models from training on client data.
↳ Scope: Legal inability to audit model architectures or demand data purging on termination.

RECOMMENDED GOVERNANCE PLAYBOOK

- **Immediate 15-Day Targeted Questionnaires:**

Issue specific inquiries to Fiserv, BNY, and AutomWorx covering model providers, hosting region, data retention policies, and training restrictions.
↳ Timeline: Dispatched within 5 business days; response due in 15 days.

- **AI Sub-Processor Inventory Registration:**

Formally register named providers (Microsoft, OpenAI, Google) with an unresolved-provider flag pending written vendor verification.
↳ Timeline: Immediate integration into Meridian's enterprise GRC repository.

- **Contractual Remediation Clauses:**

Add mandatory clauses at contract review: strict training prohibitions, mandatory 30-day sub-processor change notices, and AI audit rights.
↳ Timeline: Required for all upcoming renewals and new supplier contracts.

- **30-Day TPRC Escalation Path:**

If vendor confirmations are not received within 30 days, escalate to Meridian Third-Party Risk Committee for operational containment.
↳ Timeline: Formal review and potential transaction throttling on Day 30.

Working Demonstration & Deliverables Summary

Live Web Demonstration (Instant Presentation Mode) and Completed Audit Deliverables

STREAMLIT DEMO: INSTANT PRESENTATION MODE

- Zero Live Latency: Automatically loads pre-computed, cryptographically verified results upon page load (http://localhost:8501). No waiting for web crawls during meetings.
- Executive KPI Banner: Surfaces top metrics at a glance: 6 Assessed, 3 Confirmed AI, 2 Ruled Out, 1 Inconclusive, 1 Critical Risk.
- Per-Vendor Evidence Cards: Expandable deep-dive cards showing exact verbatim quotes, source URLs, retrieval dates, and named model providers.
- Live Execution Drawer: An optional expander allows live crawling and real-time Groq LPU inference on custom uploaded workbooks if requested.
- One-Click Download: Direct download button for the completed Meridian_Vendor_Output.xlsx.

COMPLETED EXCEL WORKBOOK DELIVERABLE

- Columns B–K Integrity: 100% byte-for-byte identical to client input. Verified by automated round-trip tests.
- Example Row (V-000): Retained verbatim as requested in specification. Formats and styling preserved.
- Columns L–V Populated: Criticality Tier, Rationale, Depth, AI Usage, Evidence, How Using, Providers, Risk, Risk Rationale, Recommended Action, Assessed By.
- 132-Entry Evidence Log Sheet: New audited sheet detailing Vendor ID, Source Tier, URL, Retrieval Date, Verbatim Excerpt, Signal Tag, and SHA-256 Snapshot Hash.
- Automated Test Suite: 18 unit tests (pytest) verifying criticality determinism, quote guard, weighting logic, and column B–K round-trip integrity.

Strategic Governance Roadmap & Next Steps

A Phased 90-Day Implementation Plan for Meridian Third-Party Risk Management

PHASE 1: DAYS 1–30

IMMEDIATE TRIAGE & ENQUIRIES

- **Core Focus:**
  Isolate high-risk exposures and dispatch formal inquiries to confirmed AI vendors.
- **Workstream 1:**
  Dispatch 15-day targeted questionnaires to Fiserv (DNA core banking), BNY (RTP rail), and AutomWorx.
- **Workstream 2:**
  Register named AI model providers (Microsoft, OpenAI, Google) in Meridian's GRC inventory.
- **Key Deliverable:**
  Targeted TPRM Questionnaires & Interim Shadow AI Sub-processor Register.
- **Success Metric:**
  100% questionnaire delivery within 10 days; 0 unvetted external models processing live data.

PHASE 2: DAYS 31–60

ESCALATION & CLAUSE REMEDIATION

- **Core Focus:**
  Enforce contractual safeguards and escalate unresponsive or unverified vendor claims.
- **Workstream 1:**
  Escalate unconfirmed vendor responses to Meridian Third-Party Risk Committee (TPRC).
- **Workstream 2:**
  Demand formal architecture data-flow diagrams from Fiserv and BNY confirming training boundaries.
- **Key Deliverable:**
  Executed AI Model Contract Addenda & Mandatory 30-Day Sub-processor Change Notices.
- **Success Metric:**
  100% of Critical vendors contractually bound by training prohibitions and audit rights.

PHASE 3: DAYS 61–90

CONTINUOUS OSINT AUTOMATION

- **Core Focus:**
  Transition from point-in-time assessment to continuous, automated third-party AI discovery.
- **Workstream 1:**
  Integrate OSINT collectors into quarterly CI/CD scheduled crawls with automated diff alerting.
- **Workstream 2:**
  Conduct scheduled manual deep-dives on bot-protected vendors (Terrapin Technologies).
- **Key Deliverable:**
  Automated Quarterly Crawl Engine & Executive Board TPRM Risk Posture Dashboard.
- **Success Metric:**
  Continuous, auditable third-party visibility across 100% of Meridian's vendor ecosystem.

Discussion & Questions

Thank you for your time and engagement. Key discussion prompts for the Third-Party Risk Committee:

- 1. Questionnaire Prioritization: Validating the 15-day targeted questionnaire scope for Fiserv, BNY, and AutomWorx.
- 2. Inconclusive Handling: Endorsing our methodology of isolating Terrapin Technologies as the sole honest coverage gap.
- 3. Enterprise GRC Integration: Operationalizing quarterly automated OSINT crawls within Meridian's existing risk tools.

AIMAN DHANANI • REGISTRATION NUMBER: 24BYB0033

Cyber Strategy Practice | Optiv Consulting | VIT Campus Engagement
Deliverables: data/Meridian_Vendor_Output.xlsx | Streamlit Presentation Demo | Unit Tests (18/18 Pass)
Repository: https://github.com/Aiman-D/optiv-case-study-1 | Confidential | September 2026